

THANH PHAM

Offensive Security Team Lead · DFIR & Malware Reverse Engineering · ISO/IEC 27001 Auditor

0937227240 · phmngcthanh@gmail.com · linkedin.com/in/thanh-pn · ISC2 ID 1636958 · OSID OS-57151582 · Ho Chi Minh City, Vietnam

PROFESSIONAL SUMMARY

Offensive security and DFIR professional with 6+ years of hands-on information-security experience — including 3+ years of professional red-team and consulting work — across enterprise, financial, and critical-infrastructure systems. OSCP- and CRYPTO-certified red teamer *and* PECB-certified ISO/IEC 27001 auditor, pairing exploitation, malware reverse engineering, and secure-architecture advisory with incident response and GRC. Experienced testing across the full SDLC (development, staging, production), advising clients on security architecture, and running forensic investigations end to end. MSc in Information Security (in progress); recipient of the Black Hat Asia 2025 Briefing Scholarship.

CORE SKILLS

Offensive Security & Red Team — Penetration testing & red teaming across the full SDLC (development, staging, production); web / API / network / infrastructure testing, Active Directory attacks, lateral movement, privilege escalation, exploit & PoC development, OSINT

DFIR & Malware Reverse Engineering — Incident response, disk & memory forensics, hardware-level data recovery (PC-3000), malware RE (Windows PE, .NET, Android), C2 analysis, threat intelligence

Security Architecture & Advisory — Secure design & architecture review, network segmentation, secure component selection, AI/LLM (RAG) system security, secure SDLC

GRC & Compliance — ISO/IEC 27001 ISMS implementation & internal audit, threat modeling, OWASP Top 10, MITRE ATT&CK

Tooling — Burp Suite, Metasploit, Acunetix, Tenable Nessus, IDA Pro, Fiddler, Splunk, Maltego, Neo4j, Elasticsearch, VMware vSphere, Jira

Programming — Go, Python, C#/.NET, C/C++ (Qt); reads PHP, Java, ASP

PROFESSIONAL EXPERIENCE

Confidential — Cybersecurity Services Provider (*name available on request*) Ho Chi Minh City, Vietnam

All engagements performed under written authorization and client NDA. Client details abstracted; specifics available under confidentiality.

Offensive Security Team Lead

Aug 2025 – Present

Promoted from Cybersecurity Engineer

Jan 2023 – Aug 2025

Lead a lean offensive-security team — setting technical direction, mentoring, and prioritizing PoC/exploit development — while remaining fully hands-on across every engagement below.

Offensive Security & Red Team

- Deliver penetration testing and red-team assessments across the full software development lifecycle — development, staging, and production — so clients remediate flaws before release rather than after.
- Led a red-team adversarial simulation of a **Level-3-classified public-safety information system** (fire/emergency alerting, integrated with national fire-and-rescue authority services), ensuring compliance with Vietnamese critical-information-system regulations.
- Identified critical vulnerabilities — weak cipher usage, insecure API and SSL handling, and hard-coded credentials — in a **mission-critical enterprise messaging platform** (Windows + mobile), enabling remote command execution on end devices and full exposure of message contents.
- In a full-scope red-team engagement, gained control of **~200 domain controllers and servers**: built an OSINT credential-gathering pipeline, exploited internet-facing web services, and moved laterally via MSSQL, Redis, SMB, and Veeam while evading multiple commercial EDR/AV solutions; exploited Dell iDRAC/IPMI and VMware ESXi to achieve hypervisor and domain dominance.
- Grey-box tested a **high-throughput fintech platform** (Java Spring Boot on Kubernetes; regulated eKYC; real-time financial events) safeguarding **>8,000 billion VND** — found unrestricted file upload/download, SQL injection, IDOR in customer eKYC, and authentication bypass, and advised architecture changes that scaled capacity **~10× (to ~80,000 concurrent users/s)**.
- Reverse-engineered a widely deployed **enterprise accounting application** (Windows) and identified a design flaw enabling **remote code execution as SYSTEM** on the server.
- Chained an exposed **cloud contract-management API** (Local File Inclusion) with reverse engineering of .NET assemblies to recover hard-coded keys and contract/e-invoice signing material — demonstrating direct financial and legal risk to the client.

Digital Forensics & Incident Response (DFIR)

- Led forensic recovery of physically damaged storage media (PC-3000 Express, Hikvision systems), extracting court-admissible digital evidence across **several** cases.
- Ran end-to-end incident response on compromised **Windows web servers** (PHP, .NET) infected with gambling-redirect malware: acquired and analyzed RAM, network traffic, registry, and event logs to reconstruct the attack chain and initial access vector, extracted IOCs and malware samples, and performed eradication.
- Reverse-engineered Android malware families built with **Flutter, React Native, Kotlin, and Java** via static and dynamic analysis; characterized behavior, mapped TTPs to MITRE ATT&CK, and recovered live C2 infrastructure to support attribution and containment.
- Tracked active **mobile-banking malware campaigns** (e.g., GoldDigger, GigaBud), delivering IOCs and TTP analysis to defensive teams.
- Designed and built a **Python + Elasticsearch threat-intelligence platform** that monitors Telegram channels and alerts on credential exposure affecting client domains.

Security Architecture, Governance & Compliance

- Led a security-architecture review of a **confidential document-management platform with an integrated RAG/LLM assistant** (accessed via mobile app over VPN and an internal LAN portal): advised secure storage-component selection — steering the client away from

- community-grade object storage and self-built vector databases for sensitive data — and redesigned network segmentation to isolate storage and administrative interfaces from user-reachable zones and to eliminate plaintext (HTTP) model traffic over lower-trust networks.
- Advise organizations on **ISO/IEC 27001** implementation — guiding ISMS design and documentation and conducting independent (non-certification) internal audits to assess and improve security posture.

UIT Information Security Lab (InSecLab)

Ho Chi Minh City, Vietnam

Security Researcher (Research Assistant)

2020 – 2022

- Authored and published **several** technical research articles on emerging offensive techniques: MFA/SIM-swap and BGP hijacking, SS7-based cellular location tracing, Wi-Fi and physical eavesdropping, and AI-assisted social engineering.
- Investigated and documented malware evasion techniques — fileless execution, VRAM-resident payloads, and sandbox evasion — building proof-of-concept implementations.
- Developed and evaluated ML/GAN systems for security: integrated a GAN into an IDS/IPS to improve malware detection, demonstrated adversarial poisoning of ML-based IDS (IDSGAN), and prototyped federated learning for IoT malware detection.

EDUCATION

Academy of Cryptography Techniques

2024 – Present

Master of Science in Information Security · Expected graduation 12/2026

- Awarded the **Black Hat Asia 2025 Briefing Scholarship** (Singapore, valued \$2,000).

University of Information Technology (UIT), VNU-HCM

2019 – 2023

Bachelor of Information Security · GPA 8.08/10

- Discovered and responsibly disclosed several severe vulnerabilities to the appropriate authorities during forensics/RE research.
- Co-authored a draft paper on federated learning for malware detection on IoT devices.
- Trained 100+ students in OOP and Data Structures & Algorithms across a faculty-organized event series.

CERTIFICATIONS

Certified Red Team Operator (CRTO)	Zero-Point Security · 12/2025
PECB Certified ISO/IEC 27001 Auditor (ID 4561650-2025-09)	PECB · 09/2025
Certificate of Pedagogy for Higher Education	Vietnam · 2025
OffSec Certified Professional (OSCP)	Offensive Security · 06/2024
Developer-Centric Threat Modelling	Security Compass · 06/2024
Certified in Cybersecurity (CC)	ISC2 · 2024
Microsoft 365 Certified: Security Administrator Associate (MS-500)	Microsoft · 2022

HONORS & AWARDS

- **Black Hat Asia 2025 Briefing Scholarship** — Singapore (\$2,000), 2025
- UIT "Excellence Student" Award, 2023
- Consolation Prize, ASEAN Student Contest on Information Security (SVATTT), 2020
- Google "Quán Quân GCP", 2020
- Two full scholarships (UIT and Lac Hong University), 2019

LANGUAGES

- **English** — IELTS Academic 7.0 (Listening & Reading 8.5); TOEIC 925
- **Vietnamese** — Native